ACME ROBOTICS — INDEPENDENT SECURITY ASSESSMENT
Executive Summary | Prepared by Cobalt Security Ltd | 18 March 2026

1. ENGAGEMENT SCOPE
1.1 Cobalt Security Ltd was engaged to perform an independent penetration test of the Acme Robotics production platform.
1.2 Testing was carried out between 2 March and 13 March 2026 against the external network perimeter, the public web application, and the tenant isolation boundary.
1.3 Testing was performed as a grey-box assessment with authenticated low-privilege tenant accounts supplied by Acme.

2. FINDINGS SUMMARY
2.1 A total of 14 findings were raised: 0 critical, 2 high, 5 medium and 7 low severity.
2.2 Both high-severity findings related to missing rate limiting on authentication endpoints and were remediated by Acme on 20 March 2026.
2.3 No finding permitted access to another tenant's data. The tenant isolation boundary held under all tested conditions.

3. RETEST
3.1 Cobalt retested the two high-severity findings on 24 March 2026 and confirmed both were fully remediated.
3.2 A summary letter of attestation was issued to Acme Robotics on 26 March 2026 and may be shared with customers under NDA.

4. LIMITATIONS
4.1 This assessment covers the scope in section 1 only. Internal corporate infrastructure, physical security and social engineering were expressly out of scope.
4.2 The findings reflect the state of the platform during the testing window and are not a statement of continuous security posture.

5. METHODOLOGY
5.1 Testing followed the OWASP Web Security Testing Guide and the Penetration Testing Execution Standard.
5.2 Automated scanning was used for coverage and breadth; all reported findings were manually verified to eliminate false positives.
5.3 Findings were rated using CVSS v3.1 base scores, adjusted for the exploitability observed in the Acme environment.

6. DETAILED FINDINGS
6.1 ACM-001 (High) – Authentication endpoints accepted unlimited attempts. Remediated by per-account and per-IP rate limiting.
6.2 ACM-002 (High) – Password reset tokens did not expire on use. Remediated by single-use token invalidation.
6.3 ACM-003 (Medium) – Verbose error responses disclosed framework versions. Remediated by a generic error handler.
6.4 The remaining medium and low findings concerned response headers, cookie attributes and informational disclosure, all remediated or formally accepted by Acme with documented rationale.

7. CONCLUSION
7.1 The Acme Robotics platform demonstrated a mature security posture. No critical findings were identified and tenant isolation held throughout.